MDR · CONSOLA DE TRIAJE

MANUAL DE USUARIO

MDR de triaje asistido

Consola de detección y respuesta

Versión: 1.0

Fecha: Noviembre 2026

Índice

Introducción

1. Cómo usar este manual 3
2. Conceptos clave 4
3. Roles y permisos 5

Primeros pasos

4. Poner en marcha el sistema 6
5. Entrar y salir de la consola 7
6. Moverse por la consola 8

Operar

7. El Panel 10
8. Cómo resolver las aprobaciones 10
9. Cómo seguir la Consola 12
10. Cómo pausar la automatización y revertir contenciones 13

Investigar

11. Cómo leer una decisión 14
12. Cómo llevar un incidente 15
13. Cómo leer el mapa de la red 15
14. Ubicaciones y Watchlist 16
15. Cómo comprobar la integridad de la traza 16

Informar

16. Cómo sacar el informe en PDF 17

Configurar

17. Políticas de respuesta 18
18. Conectividad: cómo entra el MDR en cada equipo 18
19. Estado de servicios 20
20. El perfil de la red del cliente 20
21. Recortes ante fallos de contención 21

Anexos

Anexo A. Familias de ataque y su respuesta 23
Anexo B. Por qué falló una contención 23
Anexo C. Variables de entorno 24
Anexo D. Ficheros que escribe el sistema 25
Anexo E. Preguntas frecuentes 25
Anexo F. Glosario 26

Introducción

1. Cómo usar este manual

El MDR de triaje asistido recibe las alertas que ya generó el SIEM del cliente (en el laboratorio, Wazuh), separa las amenazas reales del ruido, propone una respuesta y, si la política del cliente lo permite, la ejecuta en el equipo afectado. Todo lo que decide queda en una traza que no se puede alterar sin que se note. La consola web es donde un analista ve todo eso, decide lo que le toca y lo audita después.

Este manual explica cómo hacer cada tarea de punta a punta. Está organizado como el menú de la consola, en el orden en que suele vivirse:

Bloque	Para quién	Qué cubre
Introducción	Todos	Conceptos que conviene tener claros y qué puede hacer cada uno
Primeros pasos	Todos	Poner en marcha el sistema, entrar, moverse por la consola
Operar	Analistas	El Panel, las aprobaciones, la Consola, pausar y revertir
Investigar	Analistas	Decisiones, incidentes, el mapa de la red, ubicaciones y la traza
Informar	Analistas y responsables	El informe del periodo en PDF
Configurar	Administración del MDR	Políticas, Conectividad, el perfil de la red y los recortes ante fallos

Cada tarea sigue, cuando aplica, la misma estructura:

- un párrafo con para qué sirve y cuándo se usa;
- una caja **«Quién puede»**;
- **Antes de empezar**, con lo que tiene que estar listo;
- **Pasos** numerados;
- **Qué ocurre después**, con el resultado y las reglas que conviene conocer.

Los textos entre comillas latinas, como «Aprobar», son los rótulos tal como aparecen en la pantalla. Los comandos se ejecutan desde la raíz del repositorio.

A lo largo del manual se usa un caso de ejemplo: **un ataque de fuerza bruta por SSH desde la IP 203.0.113.9 contra el servidor web-banking**. Llega como alerta, espera aprobación, se contiene, se revisa y sale en el informe del mes. La IP es de documentación: no es de nadie.

> **Nota:** el detalle técnico del laboratorio y de los flags está en el RUNBOOK (`RUNBOOK.md`); la operación en producción (servicio systemd, anclaje de la traza), en la guía de operación; la API, en la referencia de API.

2. Conceptos clave

Del SIEM a la contención

Cada alerta recorre siempre el mismo camino:

1. **Agrupación.** Las alertas repetidas del mismo origen se juntan en un incidente, y lo que ya se decidió se suprime para no repetir trabajo.
2. **Clasificación.** El incidente cae en una de diez familias de ataque, o se marca como falso positivo o «no soportada».
3. **Propuesta.** Una política determinista elige una acción de un catálogo cerrado: bloquear una IP, cortar una conexión, aislar un equipo… El modelo de lenguaje solo redacta la explicación.
4. **Filtro del cliente.** El perfil del cliente permite la acción en automático, la retiene para un analista, la sustituye por otra más suave o la veta.
5. **Ejecución y verificación.** El MDR entra por SSH en el equipo con un usuario de mínimo privilegio, ejecuta la acción y comprueba que quedó puesta.
6. **Escalada.** Si no puede contener en el equipo, sube por la cadena de cortafuegos hasta el perímetro.
7. **Traza.** Todo queda anotado y encadenado por hash.

Tres ideas que conviene tener presentes

- **El MDR no detecta: refina.** Lo que el SIEM no ve, el MDR tampoco.
- **Lo que roza un servicio lo decide una persona.** Para eso existe la cola de aprobaciones.
- **Ante la duda, lo más grave.** Si algo no cuadra, el sistema retiene o avisa; nunca da algo por contenido sin haberlo verificado.

Decisión, incidente y campaña

Concepto	Qué es
Decisión	Lo que el MDR resolvió sobre un incidente: su clase, la acción y en qué acabó
Incidente	Un ataque concreto, con sus alertas agrupadas
Campaña	Los incidentes de un mismo bloque de IPs (/24). En la consola se gestiona como un caso

Cómo acaba una decisión

Desenlace	Qué significa
Contenida	La acción se ejecutó y se verificó, en el equipo o tras escalar
Pendiente	Espera a un analista en Aprobaciones
Rechazada / reclasificada	Un analista no la ejecutó, o corrigió su clase
Degradada / vetada	La política del cliente la sustituyó por otra más suave, o la prohibió
Fallida	No se pudo contener: la consola dice por qué
Enrutada	No se contiene por diseño: se deriva a otro equipo (por ejemplo, appsec)
Falso positivo / no soportada	No era una amenaza, o cae fuera de las familias que el MDR trata

3. Roles y permisos

La consola distingue tres papeles. No son cuentas distintas en un directorio: los decide cómo se arranca el MDR (ver la sección 5).

Rol	Quién es	Pensado para
Analista	Cualquiera que entra en la consola	Ver todo, aprobar, rechazar, reclasificar, pausar, revertir, llevar casos
Operador identificado	Un analista con token personal	Lo anterior, firmado con su nombre verificado, y además editar Políticas y Conectividad
Administración del MDR	Quien tiene acceso al equipo donde corre el MDR	Arrancarlo, configurar tokens y variables, mantener el perfil de la red

Qué puede hacer cada rol

Tarea	Analista	Operador identificado	Administración
Ver todas las vistas	Sí	Sí	Sí
Aprobar, rechazar y reclasificar	Sí	Sí	Sí
Pausar la automatización y revertir contenciones	Sí	Sí	Sí
Llevar casos y la Watchlist	Sí	Sí	Sí
Editar Políticas de respuesta	-	Sí	Sí
Probar y cambiar en Conectividad, dar de alta equipos, rotar la clave	-	Sí	Sí
Arrancar y detener el MDR, tokens y variables	-	-	Sí
Cambiar el perfil de la red	-	-	Sí

Nota: en el laboratorio, `TRIAJE_POLITICA_ABIERTA=1` y `TRIAJE_CONECTIVIDAD_ABIERTA=1` dejan editar Políticas y Conectividad sin token personal. No se usan fuera del laboratorio.

Cada acción que firma alguien queda con su nombre: en la traza (quién aprobó o rechazó), en las reversiones, en los casos y en la auditoría de Políticas y Conectividad. Con token personal el nombre lo pone el MDR; sin él, lo escribe el analista y no se verifica.

Primeros pasos

4. Poner en marcha el sistema

Esta sección es para quien administra el MDR. En el laboratorio, el sistema son tres piezas: la red del banco (con el SIEM), el MDR y la consola web.

Quién puede: administración del MDR, con acceso al equipo donde se ejecuta.

Antes de empezar

Qué	Para qué
Python 3 (probado en 3.14) con PyYAML	El MDR. No hace falta entorno virtual.
Docker y Containerlab	La red del banco del laboratorio
Node.js y npm	Construir la consola web (`visor/`)
Opcional: llama.cpp y el modelo en `modelos/`	Solo para `--con-llm`

La consola web hay que construirla una vez, y de nuevo cada vez que cambie su código:

```
cd visor && npm install && npm run build && cd ..
```

Pasos

1. **Levanta la red del banco.** Tarda unos minutos:

   ```
   sh lab/lab.sh up banco
   ```

2. **Da acceso al MDR a los equipos.** Elige una de dos formas cada vez que levantas la red:
   - con el script, de una vez: `sh lab/banco/banco.sh aprovisionar` ;
   - desde la consola, equipo a equipo, como en un cliente real (sección 18).

3. **Arranca el MDR con la consola web:**

   ```
   sh reiniciar.sh
   ```

   Detiene el MDR anterior si lo había, lee las alertas de Wazuh con el perfil del banco y escribe una traza nueva en `run/trazas-AAAA-MM-DD-HHMM.jsonl` .

4. **Abre la consola** en el navegador del mismo equipo: **http://127.0.0.1:8787**.

Variante	Cuándo
`TRIAJE_CONECTIVIDAD_ABIERTA=1 sh reiniciar.sh`	Laboratorio sin tokens: deja probar y editar Conectividad
`TRIAJE_CONSOLA_OPERADORES='{"tok-ana":"ana"}' sh reiniciar.sh`	Con un token por analista (sección 5)
`sh reiniciar.sh --con-llm`	Experimental: justificación redactada por el modelo de lenguaje

Lanzar ataques de prueba

En otra terminal, `sh lab/banco/banco.sh atacar` abre un menú con trece ataques que cubren las diez familias. `atacar auto` los lanza todos una vez y `atacar continuo` sin fin. `sh lab/banco/banco.sh vigilar` muestra en la terminal la salud de los servicios del banco.

> **Ejemplo:** para el caso de este manual, en el menú de `atacar` pulsa «a» (ataque a medida) y elige una fuerza bruta SSH contra web-banking con origen 203.0.113.9. En unos segundos aparece en la Consola y, si el perfil lo retiene, en Aprobaciones.

Detener el sistema

Qué	Cómo
El MDR	Ctrl+C en su terminal. Al salir imprime un resumen de la sesión.
Los bloqueos del laboratorio, sin apagarlo	`sh lab/banco/banco.sh restaurar`
Toda la red del laboratorio	`sh lab/lab.sh down banco`

Qué ocurre después

Al reiniciar el MDR **se pierden** la pausa de la automatización, el estado operativo de Conectividad y la memoria de fallos: viven en memoria. La traza, las políticas, el inventario y las contenciones activas se conservan.

5. Entrar y salir de la consola

> **Quién puede:** cualquiera con acceso al equipo donde corre la consola y, si se exige, un token.

Los tres modos de acceso

Modo	Cómo se configura	Qué pide la consola
Abierta	Sin token: lo normal en el laboratorio	«¿Quién está al mando?» y un nombre. Arriba aparece la banda «Consola abierta»
Compartida	`TRIAJE_CONSOLA_TOKEN=<token>`	El token común y después un nombre, que no se verifica

Modo	Cómo se configura	Qué pide la consola
Identificada	`TRIAJE_CONSOLA_OPERADORES='{"token":"nombre", …}'`	El «Token de operador». El nombre sale del token y firma cada acción

Pasos

1. Abre **http://127.0.0.1:8787**. Aparece «Entrar a la consola».
2. Escribe tu token en «Token de operador», o tu nombre si la consola lo pide.
3. Deja marcada «Mantener la sesión en esta pestaña» si no quieres que se pida al recargar. El token se guarda solo en esa pestaña, nunca en disco.
4. Pulsa «Entrar». Mientras se comprueba, el botón dice «Comprobando…».

Si algo falla

Mensaje	Qué hacer
«El daemon no reconoce ese token.»	Revisa el token, o pregunta con qué tokens se arrancó el MDR
«Demasiados intentos.»	Cinco tokens distintos fallidos en un minuto bloquean 30 s. Espera la cuenta atrás
«No hay respuesta del servicio MDR…»	El MDR no está en marcha. La pantalla reintenta sola cada 5 s
«Volver a entrar» (sobre la vista)	Tu token dejó de valer mientras trabajabas. Al entrar sigues donde estabas

Salir

En la cabecera, pulsa tu nombre y elige «Cerrar sesión». En consola abierta no hay sesión que cerrar: basta con cerrar la pestaña.

6. Moverse por la consola

El menú lateral

Grupo	Entradas
—	«Panel»
Operar	«Consola», «Aprobaciones», «Contenciones activas», «Decisiones»
Investigar	«Incidentes», «Red», «Ubicaciones», «Watchlist», «Trazas»
Informar	«Informe»
Configurar	«Políticas de respuesta», «Conectividad», «Estado de servicios»

Las señales del menú dicen dónde hay algo:

Señal	Qué significa
Número ámbar en «Aprobaciones»	Decisiones que esperan a un analista. Es lo que pide acción

Señal	Qué significa
Números en «Contenciones activas» e «Incidentes»	Bloqueos vigentes y campañas sin resolver
Punto verde en «Consola»	El registro vivo está llegando
Icono rojo en «Estado de servicios»	Un servicio caído, el conector sin configurar o un equipo con problemas de conexión o configuración. Al pasar el ratón se ve el motivo

El botón del pie pliega el menú a iconos; la consola lo recuerda.

La cabecera

- **«datos en vivo»** o **«sin conexión con el daemon»**. Sin conexión, cada vista sigue mostrando lo último que recibió, con la hora.
- **La campana** activa los avisos del navegador. Cuando llega una decisión **nueva** que espera aprobación, el navegador lo notifica aunque estés en otra pestaña, con un pitido corto. La pestaña muestra siempre el número de pendientes: «(3) MDR — consola de triaje».
- **Sol o luna:** tema claro u oscuro.
- **Tu nombre:** cómo firmas, desde cuándo, «Cambiar nombre» y «Cerrar sesión».

La banda de pausa

Con la automatización en pausa, una banda roja arriba avisa de que «toda contención automática espera aprobación humana». Su botón «Gestionar» lleva a Contenciones activas (sección 10).

Operar

7. El Panel

El Panel responde a dos preguntas al llegar: «¿funciona todo?» y «¿qué me toca?».

Quién puede: cualquier analista.

La línea de salud

Una frase y cuatro indicadores:

Indicador	Qué mide	Cuándo preocupa
Servicios	Cuántos servicios del cliente están en pie	Si alguno cae
Ingesta	Cuándo llegó la última alerta del SIEM	Ámbar a los 2 min, rojo a los 15
Traza	Si la cadena está «íntegra» o «rota»	Si está rota
Conector	Cuántos equipos están verificados o con problemas	Si hay problemas

Las cifras del día

Decisiones de hoy (comparadas con ayer a la misma hora), contenidas en automático, las que esperan a un humano (con cuántas fuera del SLA), incidentes abiertos y ruido evitado. Las que piden acción se pueden pulsar.

«Te toca»

Lo que necesita a un analista, por orden de urgencia:

- **Las aprobaciones más cercanas a vencer el SLA**, con su barra de tiempo y el botón «Revisar».
- **Equipos sin acceso:** «El MDR no tiene acceso a X desde las HH:MM».
- **Campañas sin responsable**, con «Asignarme».
- **Contenciones fallidas**, con su causa en lenguaje claro. Lo que **puede ser un ataque** va primero y en rojo, como «Posible ataque en X», aunque la escalada lo haya contenido en otro equipo.

Debajo están la actividad de las últimas 24 horas, qué se está atacando, los equipos más atacados y las últimas decisiones, con enlaces a sus vistas.

8. Cómo resolver las aprobaciones

Aquí esperan las decisiones que el perfil del cliente no deja ejecutar solas: tocan un servicio, un activo crítico o son acciones que nunca se automatizan. Es el trabajo principal del analista.

Quién puede: cualquier analista. La decisión queda firmada con su nombre.

Antes de empezar

- **El SLA es de 15 minutos** desde que la decisión entra en la cola, medidos con la hora del MDR.
- Activa la campana si quieres que el navegador te avise de cada decisión nueva.

Leer la lista

Cada fila muestra la gravedad (de P1 a P4), «equipo · familia → ACCIÓN», las marcas «cascada» (la acción tumbaría otros servicios) y «escalada» (es un salto al cortafuegos), la IP de origen y su país, «sigue atacando +N» si llegaron repeticiones mientras esperaba, y la edad con su barra de SLA.

Para…	Usa
Filtrar	«Todas», «Fuera de SLA», «Críticas», «Con cascada», «Sigue atacando»
Ordenar	Más recientes, más antiguas, urgencia o gravedad
Agrupar	Por país, por campaña /24, por equipo, por familia o por gravedad

Pasos

1. **Elige una decisión** de la lista. A la derecha se abre el inspector.
2. **Lee «Si apruebas».** Qué se ejecuta, contra quién y con qué consecuencia. Si hay cascada, la lista de equipos que caerían.
3. **Lee «Por qué lo propone el motor».** La clase, la confianza, por qué necesita a un humano y la técnica ATT&CK, y debajo lo que ya pasó con ese origen.
4. **Si quieres, escribe una nota** en «Nota para la traza…». Se guarda en el caso.
5. **Decide:**

Botón	Tecla	Qué hace
«Aprobar»	A	Ejecuta la acción. Con cascada, pide confirmar «Aprobar igualmente»
«Rechazar»	R	No ejecuta nada. La amenaza queda registrada
«Reclasificar»	C	La clase estaba mal: eliges la correcta. No ejecuta nada y queda como corrección del motor

Tras decidir, el inspector salta a la siguiente pendiente.

> **Ejemplo:** llega «web-banking · acceso_credenciales → BLOQUEAR_IP», de 203.0.113.9. «Si apruebas» dice que se bloquea esa IP en web-banking, sin servicios afectados. La pulsas «Aprobar» (o la tecla A); en la Consola aparece el comando `iptables` y, segundos después, «verificada».

Decidir en bloque y con el teclado

- **Atajos:** J y K (o las flechas) para moverte, X para marcar. No actúan mientras escribes ni con un diálogo abierto.
- **En bloque:** marca varias y usa «Aprobar las N» o «Rechazar las N». **Aprobar** en bloque pide confirmación; **rechazar** en bloque, no.

Qué ocurre después

- La decisión desaparece de la cola y queda en Decisiones con tu nombre.

- **Escaladas.** Si apruebas y el equipo atacado no responde, el MDR intenta contener en su cortafuegos. Si ese salto también necesita a un humano, aparece como una aprobación nueva con la marca «escalada», que solo tiene Aprobar y Rechazar.
- **«No se aplicó el veredicto»** significa que otro analista la resolvió antes o que la decisión cambió. Mira la cola de nuevo.

9. Cómo seguir la Consola

La Consola es el registro vivo del MDR, lo mismo que imprime su terminal: incidentes, decisiones, cada comando que se ejecuta por SSH, verificaciones, escaladas, reversiones y avisos. Guarda las últimas 1000 líneas.

Quién puede: cualquier analista.

- **Filtros:** «Todo», «Decisiones», «Incidentes», «Ejecución», «Avisos», y un campo para filtrar por texto.
- **Desplazamiento automático:** se pausa si subes a leer y se reanuda al bajar al final.

Qué significa cada símbolo

Símbolo	Significado
⚠	Incidente nuevo
▶	Orden ejecutada en un equipo, con su comando exacto
✔	Verificada: la contención está puesta
✗ … NO verificada / ✗ … no se ejecutó	La contención no quedó: dice dónde, por qué y qué hacer
· … evidencia:	La salida real de SSH o sudo que lo prueba
⇪	Escalada: dónde contuvo o en qué equipos falló, y «POSIBLE ATAQUE» si lo es
↶	Reversión
✓ □ ↻	Veredicto de un analista
☰	Cambio en un caso
↩	Repetición suprimida (ruido)
↺	Actividad propia del MDR, su propio SSH visto por el SIEM
□	Pausa de la automatización
[aviso]	Aviso del sistema, por ejemplo «el MDR no tiene acceso a X»

Ejemplo: tras aprobar el caso de web-banking verás, en este orden, «▶ … BLOQUEAR_IP en web-banking (10.10.0.10): iptables -A INPUT -s 203.0.113.9 -j DROP» y «✔ … verificada — contenida en web-banking».

10. Cómo pausar la automatización y revertir contenciones

«Contenciones activas» lista lo que está bloqueado **ahora**: qué se bloqueó, a quién protege, quién lo decidió («automática», «vía escalada» o «aprobó Fulano»), su antigüedad y **cuántos intentos paró**. Una contención con intentos parados está sirviendo. El inspector muestra la gráfica de intentos antes y después del bloqueo, la regla exacta y el comando que la quita.

Quién puede: cualquier analista. Cada reversión queda en la traza con su nombre.

Pausar la automatización (el «kill switch»)

1. Pulsa el interruptor «Automatización». **No pide confirmación.**
2. Desde ese momento, **toda** contención nueva espera a un analista. Arriba aparece la banda roja.
3. Para reanudar, vuelve a pulsarlo.

Nota: pausar **no** retira las contenciones que ya están puestas, y la pausa se pierde si se reinicia el MDR.

Revertir

Botón	Qué hace
«Revertir…»	Quita una contención. Pide confirmación
«Revertir y vigilar…»	La quita y añade la IP a la Watchlist
«Revertir las N…»	Las seleccionadas
«Revertir todas (N)…» / «Revertir las de más de 7 días (N)…»	En masa. **Hay que escribir el número de contenciones** para habilitar el botón

Qué ocurre después

Revertir es real: el MDR quita la regla en el equipo y lo anota. Si el origen sigue intentándolo, volverá a llegar.

Ejemplo: el bloqueo de 203.0.113.9 en web-banking muestra «12 intentos parados» en el día. Si fuera un falso positivo (una IP de un socio, por ejemplo), «Revertir y vigilar…» lo quita y deja la IP marcada en la Watchlist.

Investigar

11. Cómo leer una decisión

«Decisiones» es el historial de lo que decidió el motor y en qué acabó.

Quién puede: cualquier analista.

Encontrarla

- **La franja de arriba** filtra al pulsarla: decisiones, contenidas en automático, pasaron por un analista, corregidas por el analista, frenadas por la política, contención fallida.
- **El buscador** encuentra por equipo, IP, identificador o país; el selector, por clase.
- **Filtros:** «Pendientes», «Falsos positivos», «Decididas por mí»… y la casilla «Incluir registros del sistema» para ver reversiones y supresiones.

Color del desenlace	Desenlaces
Verde	contenida
Rojo	fallida, vetada
Ámbar	rechazada, pendiente, degradada
Violeta	reclasificada
Gris	enrutada, falso positivo, no soportada, sin acción

Leer el detalle

El detalle se lee como una historia de seis pasos: la alerta del SIEM, la clasificación, la propuesta del motor, la política del cliente («automática», «retenida — espera tu aprobación», «degradada», «vetada»), el analista y la ejecución, con dónde quedó contenida y el comando exacto.

Si la contención falló, cada intento lleva su causa en lenguaje claro y la evidencia debajo, por ejemplo «intento en atm: equipo sin aprovisionar — dalo de alta o fija su clave del host en Conectividad». El anexo B tiene todas las causas.

Nota: las causas marcadas **POSIBLE ATAQUE** (la clave del equipo cambió, alguien deshizo la contención, un equipo que funcionaba dejó de hacerlo) no son un problema de configuración. Compruébalo por otro canal antes de tocar nada.

«Salto de respaldo» significa que el perfil tenía la cadena de cortafuegos rota y la escalada siguió hasta el perímetro: hay que corregir el perfil (sección 20).

El detalle incluye también la justificación (por plantilla o redactada por el modelo, con lo que consultó), el origen y «Qué hacer después»: la recomendación y los pasos del runbook. Desde aquí se abren el grafo del incidente, el perfil del atacante, la contención y la prueba en Trazas.

12. Cómo llevar un incidente

Un incidente agrupa los ataques de un mismo bloque de IPs (/24), la campaña. Cada uno muestra su estado («Nuevo», «En revisión», «Resuelto»), si está activo ahora (punto rojo: atacó en la última hora) y su responsable. El panel del caso cuenta la historia del ataque: contra qué equipos, cuántas decisiones y bloqueos, y la cronología.

Quién puede: cualquier analista. Cada cambio queda en la traza con su nombre y la hora.

Pasos

1. En «Incidentes», elige la campaña. Por defecto se ven las abiertas.
2. Pulsa «asignarme» para hacerte responsable.
3. Pasa el estado a «En revisión» y escribe lo que vas viendo en «Nota»; «Guardar en el caso».
4. Para cerrarlo, escribe por qué y pulsa «Resolver con esta nota».

Ejemplo: la campaña 203.0.113.0/24 tiene una decisión contenida contra web-banking. Te la asignas, compruebas en «Contra qué equipos» que no tocó a nadie más y la resuelves con la nota «Fuerza bruta contenida en el host; sin más actividad del bloque».

El historial de un caso no se puede borrar.

13. Cómo leer el mapa de la red

«Red» dibuja la red del cliente con la actividad de cada equipo. Se lee de arriba abajo: el carril de internet y los orígenes que más atacan, el tronco de cortafuegos y las zonas, cada una colgada del cortafuegos que la protege. Una red detrás de su propio cortafuegos sale en su propia rama.

Quién puede: cualquier analista.

Símbolo	Estado del equipo
⚠	atacado
▯	espera tu decisión
✓	contenido
⚠ (ámbar)	caería en cascada
↗	origen de ataques
✕	caído
○	sin actividad

Capas y acciones

- **«ataques»:** flechas rojas desde el origen; el grosor es el volumen.
- **«cascada»:** en ámbar, de un equipo caído a los que dependen de él.

- **«dependencias»:** en violeta, quién depende de quién. Dentro de una zona se dibuja como un arco por la derecha de la columna.
- **«solo con actividad»** pliega las zonas tranquilas; una zona también se pliega pulsando su píldora.
- **El buscador** encuentra un equipo por nombre o IP. Al elegirlo, se atenúa lo que no tiene relación y se abre su ficha: riesgo, ataques recibidos y contenidos, atacantes, eventos y enlaces.

Nota: los equipos y las dependencias del mapa salen del **perfil del cliente**, no de Conectividad. Si el perfil tiene algo roto, una franja ámbar encima del mapa lo lista (sección 20).

Perfil del atacante. Se abre pulsando una IP: su riesgo, los equipos que atacó, su actividad y su línea de tiempo. «DNS inverso: Resolver» solo consulta si lo pides y solo para IPs públicas.

14. Ubicaciones y Watchlist

Ubicaciones muestra en un mapamundi de dónde vienen los ataques. La geolocalización es aproximada y no consulta servicios externos. Tres métricas: «En curso» (aún no contenidos), «Total» y «Mitigados». Al pulsar un país, «En curso» lleva a Aprobaciones de ese país; las otras dos, a Decisiones. Las IPs internas, de laboratorio o sin geolocalizar solo salen en la tabla.

Watchlist es tu lista de indicadores sospechosos: una IP o un bloque /24, con una nota. **Es solo una anotación**: no cambia ninguna decisión del motor. Las IPs vigiladas salen marcadas con ⚑ en la Red y en el perfil del atacante. «Quitar» no pide confirmación.

Quién puede: cualquier analista.

15. Cómo comprobar la integridad de la traza

«Trazas» es el registro auditable: cada decisión, veredicto, reversión y cambio de caso, encadenado por hash. Si alguien altera un registro, la cadena se rompe en ese punto y la consola lo dice.

Quién puede: cualquier analista.

1. Mira la franja de arriba: «Cadena íntegra» o «Cadena rota en el registro #N». Se comprueba cada 30 segundos; «Verificar ahora» la comprueba en el momento.
2. Lee la marca de cada fila: ✓ verificado, ✗ alterado, ⚠ posterior a una rotura.
3. Pulsa una fila para ver el registro, su «Causa del fallo» si la tiene, y la prueba de la cadena (el hash anterior y el suyo). «Copiar el registro (JSON)» lo copia para auditarlo fuera.

Si la cadena se rompe, el inspector abre directamente el registro alterado. Fuera de la consola, se comprueba con `python3 -m prototipo.servicio.traza --verificar run/trazas-….jsonl`.

Informar

16. Cómo sacar el informe en PDF

«Informe» resume un periodo: indicadores (tasa de falsos positivos, resuelto sin humano, escalado a humano, tiempo medio de respuesta, dentro del SLA, ruido evitado), rankings de activos, familias, orígenes y analistas, la cobertura MITRE ATT&CK y un resumen redactado.

Quién puede: cualquier analista.

Antes de empezar

El modo «En vivo» no se exporta: elige un periodo cerrado («Este mes», «Este año» o «Rango…»).

Pasos

1. Elige el periodo.
2. En «Qué incluir», marca las secciones. Por defecto van todas salvo el anexo con el detalle de cada decisión.
3. Rellena «Para» con el cliente y el área destinataria. Debajo verás el nombre del archivo, por ejemplo `Informe-MDR-2026-11`.
4. Pulsa «Vista previa del PDF». Se abre el documento en hojas A4: portada, comparación con el periodo anterior, recomendaciones, integridad de la traza y el pie «Confidencial · uso interno del cliente».
5. Pulsa «Guardar PDF» y, en el diálogo de impresión del navegador, elige guardar como PDF.

Ejemplo: el informe de noviembre incluye la campaña 203.0.113.0/24 entre los orígenes, el caso de web-banking entre los activos atacados y su contención dentro del SLA.

Configurar

17. Políticas de respuesta

Decide qué respuestas se ejecutan solas y cuáles esperan a un analista.

Quién puede: operador identificado (o `TRIAJE_POLITICA_ABIERTA=1` en el laboratorio). Cada clic se guarda al momento, **sin confirmación**, y queda en la auditoría con su nombre.

- **«Por tipo de ataque».** Cada familia muestra su acción y un selector AUTO / HUMANO. Las que llevan candado («freno duro / nunca automática») no se pueden poner en automático; las que «se trían y enrutan» no tienen acción. «detalle» muestra el impacto, los vetos y el runbook.
- **«Por zona y dispositivo».** Postura por zona (AUTO o HUMANO; el plano de gestión no se edita) y por equipo (HEREDA, AUTO o HUMANO), con su criticidad y cuántos equipos caerían en cascada.

Nota: si la familia **o** la zona está en HUMANO, prevalece HUMANO. Lo que se edita en la consola solo puede **quitar** automatización respecto al perfil; nunca añadirla.

18. Conectividad: cómo entra el MDR en cada equipo

El MDR contiene entrando por SSH en cada equipo con un usuario propio (`triaje`). Ese usuario solo puede ejecutar, por sudo, los comandos del catálogo que permite el **papel** del equipo: servidor, cortafuegos o puesto. Esta vista lo gestiona todo sin tocar scripts.

Quién puede: ver, cualquier analista. Probar, dar de alta, cambiar o rotar: operador identificado (o `TRIAJE_CONECTIVIDAD_ABIERTA=1` en el laboratorio).

Nota: es una vista delicada. La **clave privada del conector nunca llega al navegador**: solo se ven la pública y las huellas. **Ninguna clave del host se acepta sola**: siempre hay que confirmar que la huella coincide con la que imprimió el equipo.

Lo que se ve

- **La franja de permisos**, con lo que puede hacer tu sesión.
- **La clave del conector**, con su huella y «Copiar clave pública». Si no existe, «Generar la clave del conector» (recomendada en ed25519).
- **Las cifras:** equipos contenibles, conexión verificada, clave del host cambiada, sin aprovisionar.
- **La tabla de equipos**, con su papel, el estado de la conexión, si su sudoers coincide con su papel y su clave del host.

Estado	Significado
verificada	La última prueba pasó. Con más de 24 h, «conviene volver a probar»
bloqueada	**La clave del host cambió.** Puede ser una suplantación
privilegio de más	sudo permite más de lo que su papel necesita
sin aprovisionar	No acepta la clave del conector o falta su clave del host
sin acceso / fallo	No se pudo conectar, o el comando falló
sin probar / alta pendiente	Aún no se ha probado / se está dando de alta

El aviso rojo encima del estado aparece cuando una **contención real** falló en ese equipo: «la última contención falló», «posible ataque» o «sin acceso». Solo resta confianza: una prueba verde anterior no lo tapa. Se quita con una contención correcta o con una prueba nueva que pase.

Dar de alta un equipo

Antes de empezar

- La zona del equipo tiene que existir en el perfil (sección 20).
- Necesitas a alguien que administre el equipo para ejecutar en él el paquete de alta.

Pasos

1. Pulsa «+ Añadir equipo».
2. **Inventario:** nombre, IP, zona, función, criticidad, interfaz y de qué equipos depende.
3. **Papel y reglas:** elige servidor, cortafuegos o puesto. El papel marca las acciones que se pueden ejecutar en ese equipo. Añade los servicios que se pueden parar y las cuentas que se pueden bloquear; las cuentas del sistema nunca se bloquean.
4. **Paquete de alta:** un script, un playbook de Ansible o solo el sudoers. El administrador del equipo lo ejecuta en él. Lleva solo la clave pública, no pide contraseñas de administrador, crea el usuario `triaje` y su sudoers y aparta los sudoers antiguos del conector.
5. **Verificar y dar de alta:** «Leer la clave del equipo», marca «Coincide con la que imprimió el equipo» y pulsa «Dar de alta». Hace la prueba completa.

Qué ocurre después

Si la prueba pasa, el equipo entra en el motor y en el mapa. Hasta entonces está «pendiente» y el MDR no actúa en él.

Un equipo que ya existe

- **«Fijar la clave del host»**, para uno que nunca se conectó: «Leer la clave del equipo», compara la huella y «Fijar esta clave».
- **«Clave del host cambiada»:** muestra la fijada frente a la que presenta ahora. **Compruébalo por otro canal** antes de «Aceptar la nueva clave…».
- **«Papel y reglas»:** cambia el papel o quítalo. Si alguien tocó el sudoers del equipo, verás lo que **sobra** (rojo) y lo que **falta** (ámbar), y podrás «Generar paquete de corrección».
- **«Cómo entra el conector»:** puerto y usuario. «Probar y guardar» solo guarda si la prueba pasa.

Nota: la consola solo quita altas pendientes y papeles. Un equipo ya dado de alta se quita de `run/inventario-operativo.yml` y reiniciando el MDR.

Rotar la clave del conector

Ningún equipo se queda sin acceso por el camino:

1. «Iniciar: generar el par nuevo».
2. «Añadir y probar en todos»: la clave nueva entra en cada equipo junto a la vieja y se prueba.
3. «Retirar la clave vieja…» (pide confirmación; desde ahí ya no se puede cancelar) y «Finalizar».

Ejemplo: si la contención en web-banking hubiera fallado con «equipo inalcanzable», su fila mostraría encima «la última contención falló · equipo inalcanzable · hace 1 min». Si el equipo estaba verificado, diría «posible ataque»: alguien pudo cortar el acceso del SOC.

19. Estado de servicios

Solo es de consulta.

Quién puede: cualquier analista.

- **«MDR propio»:** si el lazo de decisión está vivo, cuándo llegó la última alerta del SIEM y cuántas se procesaron.
- **«Conector»:** cuántos equipos están verificados o con problemas, con el enlace a Conectividad.
- **Los servicios del cliente**, con los caídos primero. Un servicio caído dice «afecta a …» los que dependen de él; uno que depende de un caído, «responde, pero X está caído».
- Si la muestra del monitor tiene más de un minuto, la vista avisa de que es lo último que se supo.

El icono de esta vista en el menú se pone **rojo** con cualquiera de los problemas de la sección 6.

20. El perfil de la red del cliente

Todo lo que el MDR sabe del cliente vive en su **perfil**, por ejemplo `prototipo/perfiles/bancario.yml`.

Quién puede: administración del MDR. **Los cambios en el perfil exigen reiniciar el MDR.**

Sección	Qué define
`activos`	Los equipos: IP, función, criticidad, servicios y **de quién dependen** (depende_de)
`topologia`	La cadena de contención: qué equipos se contienen y cuál es su cortafuegos (`gateway`)
`red`	Para el mapa: nodos extra (internet, switches), enlaces y zonas
`ip_gestion` , `redes_internas`	El plano de gestión, que nunca se corta, y las redes propias

Sección	Qué define
`origenes_legitimos`, `terceros_confiables`	Quién no es atacante, y a quién no se bloquea sin humano
`continuidad`, `excepciones`	Qué se automatiza según el impacto, y los servicios que nunca se tocan solos
`rutas`	Adónde se enruta lo que no se contiene (por ejemplo, appsec)

Las dependencias deciden la cascada: si `middleware` depende de `core-db` y cae `core-db`, middleware cae con él. El motor usa este dato para no aislar algo que tumbe servicios sin aprobación, y el mapa lo dibuja en la capa «dependencias».

Añadir una red nueva

Hay que completar cuatro sitios: sus equipos en `activos`; su cortafuegos y sus equipos en `topologia`, con su `gateway`; sus enlaces en `red.enlaces`, y la zona en `red.zonas`. Si solo se añaden los `activos`, los equipos salen en «Sin ubicar» y la escalada usa los cortafuegos perimetrales en vez del suyo. Una vez creada la zona, Conectividad ya puede dar de alta equipos en ella, y heredan el cortafuegos de sus vecinos.

Borrar un equipo

Hay que quitarlo de **todas** las secciones. Si se borra a medias, el MDR lo avisa al arrancar (en la Consola) y en la franja ámbar del mapa:

Si queda…	Qué pasa
en `topologia`, pero no en `activos`	Se sigue pintando y **se sigue conteniendo** en él
otros equipos que dependían de él	Su cascada desaparece
un `gateway` apuntando a un cortafuegos borrado	La escalada salta a los cortafuegos perimetrales («salto de respaldo»), pero **la cuarentena (AISLAR_NODO) de esos equipos deja de poder ejecutarse** hasta que se corrija

El historial del equipo borrado se conserva en Decisiones y en Trazas.

21. Recortes ante fallos de contención

Están **apagados por defecto** y se encienden con `=1` al arrancar el MDR. No cambian qué se contiene: solo ahorran conexiones que no podían servir.

Quién puede: administración del MDR.

Variable	Efecto
`TRIAJE_FALLO_RAPIDO`	Si la primera conexión ni siquiera entra en el equipo, no se repite contra él. La escalada sigue igual

Variable	Efecto
`TRIAJE_PRECHECK_APROVISIONADO`	No intenta en un equipo que la consola sabe sin clave del host. Escala, o queda fallida con su motivo
`TRIAJE_ESCALADA_SOLO_APROVISIONADOS`	Salta los cortafuegos de escalada sin aprovisionar y lo anota («salto omitido»)
`TRIAJE_MEMORIA_FALLOS`	Tras 3 fallos de acceso seguidos a un equipo en 5 minutos, deja de intentar en él y escala directo. Avisa una vez («el MDR no tiene acceso a X») y lo reprueba cada 60 s sin sudo
`TRIAJE_ACCION_NO_EJECUTABLE`	Si la prueba de Conectividad de las últimas 24 h dice que falta la regla de esa acción en el sudoers, no la intenta

Nota: ninguno se activa ante una clave del host cambiada ni ante una contención deshecha: pueden ser un ataque y se quieren ver en cada intento.

Anexos

Anexo A. Familias de ataque y su respuesta

Familia	Respuesta	¿Puede ser automática?
acceso_credenciales (fuerza bruta)	BLOQUEAR_IP en el equipo; si falla, en el cortafuegos	Sí, si el perfil lo permite y la confianza llega al umbral
reconocimiento (escaneos)	BLOQUEAR_IP	Igual que la anterior
servicio_expuesto	BLOQUEAR_IP si el servicio está expuesto; si no, falso positivo	Igual que la anterior
explotacion_conocida	Se tría y se **enruta** al equipo de appsec; no se contiene	—
abuso_de_cuenta	FORZAR_CAMBIO_PASS (bloquea la cuenta)	**Nunca**
integridad_fichero	AISLAR_NODO (cuarentena en el cortafuegos de borde)	**Nunca**
denegacion_servicio	LIMITAR_BANDA en la víctima	**Nunca**
acceso_consumado	MATAR_CONEXION (corta la sesión viva)	Según el perfil
exfiltracion	BLOQUEAR_DESTINO en el borde	**Nunca**
malware	AISLAR_NODO	**Nunca**

Lo que no encaja en ninguna familia se marca «no soportada» y no se actúa. Si es grave, pasa a un analista.

Anexo B. Por qué falló una contención

Cuando una contención no queda, el MDR dice por qué en la Consola, en Decisiones, en Trazas y en «Te toca».

Clase	Qué pasó	Qué hacer
F1	Orden rechazada antes de salir	Revisa la alerta: un parámetro no era válido
F2	Equipo sin aprovisionar	Dalo de alta o fija su clave del host en Conectividad
F3	**La clave del host cambió**	**Posible suplantación.** Compruébalo por otro canal antes de aceptar la clave
F4	El equipo no acepta la clave del conector	Ejecuta su paquete de alta
F5	Equipo inalcanzable	Comprueba que el equipo y sshd están en marcha y que la red llega

Clase	Qué pasó	Qué hacer
F6	sudo deniega la acción	Revisa el papel y el sudoers. Si falta la regla, es una «acción no ejecutable en este equipo»
F7	La acción falló dentro del equipo	Revisa la salida del comando
F8	**Se aplicó, pero ya no está**	**Posible contramedida:** alguien pudo deshacerla
F9	El conector no tiene clave	Genera la clave del conector en Conectividad
F10	Causa no identificada	Revisa la salida en bruto

Nota: si el equipo **estaba verificado** y ahora da F4, F5 o F6, es una **regresión** y se marca como posible ataque: alguien pudo cortar el acceso del SOC. Compruébalo antes de reaprovisionar.

Anexo C. Variables de entorno

Variable	Efecto
`TRIAJE_CONSOLA_TOKEN`	Token compartido. Con él, la consola pide token
`TRIAJE_CONSOLA_OPERADORES`	`{"token":"nombre", …}`: un token por persona, que firma sus acciones
`TRIAJE_CONECTIVIDAD_ABIERTA=1`	Laboratorio: deja probar y editar Conectividad sin operador identificado
`TRIAJE_POLITICA_ABIERTA=1`	Laboratorio: deja editar Políticas sin operador identificado
`TRIAJE_SLA_SEG`	SLA de la respuesta humana en segundos (900 por defecto)
`TRIAJE_RDNS=1`	Permite el DNS inverso de IPs públicas
`TRIAJE_NODO_GESTION`	Contenedor desde el que sale el SSH del conector. `reiniciar.sh` la fija en el banco
`TRIAJE_SSH_MODO`	`clave` (vía el nodo de gestión), `directo` (desde este equipo) o `password` (laboratorio). Sin clave ni modo, no ejecuta nada
`TRIAJE_SSH_USUARIO`, `TRIAJE_SSH_CLAVE`, `TRIAJE_SSH_KNOWN_HOSTS`	Usuario, clave privada y huellas del conector
`TRIAJE_TRAZA_CLAVE`	Firma la cadena de la traza con HMAC. Sin ella, el arranque avisa «SIN firma HMAC»
`TRIAJE_ANCLA`	Ancla la traza en el syslog del SIEM
Recortes ante fallos	Los cinco de la sección 21

Anexo D. Ficheros que escribe el sistema

Todos viven en `run/`, junto a la traza.

Fichero	Contenido
`trazas-*.jsonl`	La traza encadenada. Al reiniciar, el MDR recupera de aquí las contenciones activas
`politica-operativa.yml`	Lo editado en Políticas
`politica-auditoria.jsonl`	Quién cambió qué en Políticas
`conectividad-operativa.yml`	Usuario y puerto por equipo
`conectividad-auditoria.jsonl`	Cada prueba y cambio en Conectividad
`conectividad-pruebas.json`	La última prueba de cada equipo
`conectividad-rotacion.json`	La rotación de clave en curso
`inventario-operativo.yml`	Los equipos dados de alta desde la consola y sus papeles
`watchlist.json`	La Watchlist

Anexo E. Preguntas frecuentes

Operar

¿Por qué una contención no se ejecutó sola? Porque el perfil del cliente la retiene: toca un servicio, un activo crítico, un equipo interno, o es de las acciones que nunca se automatizan. O porque la automatización está en pausa. La decisión espera en Aprobaciones y su detalle dice por qué necesita a un humano.

¿Cómo deshago un bloqueo? En «Contenciones activas», «Revertir…» en su fila. El MDR quita la regla en el equipo y lo anota con tu nombre. Para un bloqueo en masa hay que escribir el número de contenciones.

¿Qué hago si sale «posible ataque»? No lo trates como un problema de configuración. Comprueba por otro canal qué pasa con ese equipo (la clave de su host, si alguien deshizo la regla, si alguien cortó el acceso del SOC) antes de reaprovisionarlo o aceptar una clave nueva.

¿Por qué no me llegan avisos? Activa la campana y acepta el permiso del navegador. Solo avisa de decisiones **nuevas**, no de las que ya estaban en la cola al abrir la consola.

Red y configuración

¿Por qué un equipo sale en el mapa si no lo di de alta? Porque el mapa sale del perfil del cliente, no de Conectividad. Conectividad solo gestiona cómo entra el MDR en cada equipo; las altas nuevas entran en el mapa cuando se completan.

¿Por qué no puedo editar Políticas o Conectividad? Esas vistas exigen un operador identificado por token. Pide un token personal a quien administra el MDR.

¿Se pierde algo al reiniciar el MDR? La pausa, el estado operativo de Conectividad y la memoria de fallos. La traza, las políticas, el inventario y las contenciones activas se conservan.

El sistema

¿El modelo de lenguaje decide qué hacer? No. La acción la propone una política determinista y la filtra el perfil del cliente. El modelo solo explica, y su explicación se descarta si no se apoya en los datos.

¿Qué significa «no soportada»? Que la alerta cae fuera de las diez familias que el MDR trata. El sistema prefiere decirlo a inventar una respuesta. Si es grave, pasa a un analista.

¿El MDR sustituye al SIEM o a un antivirus? No. Refina lo que el SIEM ya detecta; lo que el SIEM no ve, el MDR tampoco.

Anexo F. Glosario

Término	Significado
Alerta	Lo que envía el SIEM cuando detecta algo. Es la entrada del MDR
Aprobación	Decisión que el perfil retiene para que la resuelva un analista
Campaña	Los incidentes de un mismo bloque de IPs (/24). Se gestiona como un caso
Cascada	Equipos que caen si cae otro del que dependen
Causa del fallo	Por qué no quedó una contención: de F1 a F10
Clase	Lo que el motor concluye de un incidente: un tipo de amenaza, un falso positivo o «no soportada»
Conector	La parte del MDR que entra por SSH en los equipos para contener
Contención	La acción que corta el ataque: bloquear una IP, cortar una conexión, aislar un equipo…
Decisión	Lo que el MDR resolvió sobre un incidente, con su desenlace
Deriva del sudoers	Diferencia entre lo que sudo permite en un equipo y lo que su papel necesita
Escalada	Contener en el cortafuegos cuando no se puede en el equipo atacado
Familia	El tipo de ataque: fuerza bruta, reconocimiento, malware… Hay diez
Huella	La identidad de la clave del host de un equipo, que se fija una vez
Incidente	Un ataque concreto, con sus alertas agrupadas
Kill switch	La pausa de la automatización: todo pasa a esperar a un analista
Operador identificado	Analista que entra con su token personal y firma con su nombre
Papel	Servidor, cortafuegos o puesto: decide qué acciones se pueden ejecutar en un equipo
Perfil	Todo lo que el MDR sabe del cliente: equipos, red, dependencias y política
Posible ataque	Fallo que no puede tratarse como configuración: clave cambiada, contención deshecha o regresión
Regresión	Un equipo que estaba verificado y dejó de funcionar
Reversión	Quitar una contención y devolver el equipo a como estaba
SIEM	El sistema de detección del cliente. En el laboratorio, Wazuh

Término	Significado
SLA	Plazo para que un analista resuelva una aprobación: 15 minutos
Supresión	Repeticiones de algo ya decidido que no se vuelven a procesar
Traza	El registro de todo lo que decide el MDR, encadenado por hash
Watchlist	Lista de IPs o bloques que el analista marca como sospechosos. No cambia decisiones
Zona	Grupo de equipos de la red del cliente, colgado de un cortafuegos